

Методика выявления компьютерных атак на основе атрибутивных метаграфов

И. Т. Латыпов¹, М. А. Еремеев¹

¹ Российский технологический университет РТУ МИРЭА

Abstract

В статье предложена методика выявления компьютерных атак в информационных системах на основе аппарата атрибутивных метаграфов. Методика развивает многоуровневую модель атаки, впервые описанную в работе [1], и включает формализацию тактик, методов и целей злоумышленника в виде вершин и дуг метаграфа с атрибутами. Представлен алгоритм сопоставления наблюдаемых событий с эталонными паттернами атак, основанный на частичном изоморфизме атрибутивных метаграфов. Приведены результаты имитационного эксперимента в среде, моделирующей поведение атакующего по тактикам MITRE ATT&CK. Методика демонстрирует высокую точность (94,3 %) и полноту (89,7 %) при низком уровне ложных срабатываний (3,1 %). Подход может быть интегрирован в системы мониторинга безопасности для повышения устойчивости к сложным и малозаметным атакам.

Ключевые слова: атрибутивный метаграф, выявление атак, многоуровневая модель, MITRE ATT&CK, изоморфизм графов, информационная безопасность, ФСТЭК.

Abstract

This paper presents a methodology for detecting cyber attacks in information systems using attributive metagraphs. The approach extends the multilevel attack model introduced in [1] by formalizing attacker goals, tactics, and techniques as attributed vertices and edges. A pattern-matching algorithm based on partial isomorphism of attributive metagraphs is proposed to correlate observed events with known attack signatures. Simulation results in a MITRE ATT&CK-aligned environment demonstrate high precision (94.3 %) and recall (89.7 %) with a low false positive rate (3.1 %). The methodology is suitable for integration into security monitoring systems to enhance resilience against sophisticated and stealthy threats.

Keywords: attributive metagraph, attack detection, multilevel model, MITRE ATT&CK, graph isomorphism, information security, FSTEC.

Введение

Современные информационные системы всё чаще подвергаются целенаправленным атакам, использующим легитимные инструменты и обходящие традиционные средства защиты. В этих условиях возрастает роль **моделей, способных отражать логику атаки**, а не только её внешние признаки.

Традиционные системы обнаружения вторжений (IDS/IPS) в основном полагаются на сигнатурный анализ или статистические аномалии. Однако такие подходы неэффективны при столкновении с **адаптивными атаками**, использующими Living-off-the-Land (LotL) техники, где злоумышленник применяет легитимные системные утилиты (например, PowerShell, WMI,

PsExec) для выполнения вредоносных действий. В таких сценариях отсутствуют чёткие сигнатуры, а поведение может не выходить за рамки статистической нормы.

В работе [1] предложена **многоуровневая модель компьютерной атаки**, основанная на атрибутивных метаграфах, позволяющая формализовать взаимосвязи между целями злоумышленника, тактиками и методами реализации. Эта модель предоставляет теоретическую основу для построения семантически насыщенных систем анализа угроз. Однако в указанной работе не была детализирована **практическая методика выявления атак** на основе этой модели.

Настоящая статья устраняет этот пробел и предлагает **комплексную методику**, пригодную для внедрения в системы мониторинга безопасности, соответствующие требованиям ФСТЭК России и ГОСТ Р 56939–2024. Методика включает не только формализацию, но и алгоритмическую реализацию, оценку эффективности и рекомендации по интеграции.

Теоретические основы

Метаграфы как инструмент моделирования сложных систем

Метаграфы были впервые предложены как обобщение направленных графов для моделирования систем с гиперсвязями. В отличие от классического графа, где дуга соединяет две вершины, в метаграфе дуга может соединять **множества вершин**, что позволяет естественным образом описывать отношения «многие ко многим». Это особенно важно в контексте информационной безопасности, где одно действие (например, запуск скрипта) может одновременно затрагивать несколько объектов: процесс, файл, сетевой сокет, учётную запись.

Формально метаграф задаётся как

$$G = (V, E),$$

где V — конечное множество вершин, $E \subseteq 2^V \times 2^V$ — множество дуг. Каждая дуга $e = (S, T) \in E$ интерпретируется как переход от множества источников $S \subseteq V$ к множеству целей $T \subseteq V$.

Атрибутивные расширения

Для применения в ИБ метаграф необходимо расширить атрибутами, отражающими семантические свойства компонентов системы. Вводятся функции атрибуции:

$$A_V : V \rightarrow \mathcal{A}_V, \quad A_E : E \rightarrow \mathcal{A}_E,$$

где $\mathcal{A}_V$ и $\mathcal{A}_E$ — домены атрибутов.

Примеры атрибутов: - Для вершины «пользователь»: роль (администратор, гость), уровень доверия, принадлежность к группе. - Для вершины «процесс»: исполняемый файл, хеш, родительский процесс. - Для дуги «доступ к файлу»: тип доступа (чтение/запись), протокол, временная метка, тактика MITRE ATT&CK.

Такое расширение позволяет строить **контекстно-зависимые модели**, в которых не только структура, но и семантика играют ключевую роль в анализе.

Связь с существующими фреймворками

Предлагаемая модель органично интегрируется с: - **MITRE ATT&CK** — тактики и техники становятся атрибутами дуг; - **STIX 2.1** — объекты STIX (indicator, attack-pattern, malware) могут быть отображены в вершины метаграфа; - **Cyber Kill Chain** — этапы цепочки атаки соответствуют уровням модели.

Это обеспечивает совместимость с существующей экосистемой кибербезопасности и упрощает внедрение.

Многоуровневая модель атаки

На основе [1] выделяются три уровня абстракции, отражающие иерархию целей и средств злоумышленника.

Стратегический уровень

На этом уровне формулируются **бизнес-цели** атаки: - Кража персональных данных (в соответствии с 152-ФЗ); - Нарушение целостности финансовых транзакций; - Вывод критической инфраструктуры из строя.

Каждая цель представляется как вершина с атрибутами `goal_type`, `impact_level`, `regulatory_1`.

Тактический уровень

Тактики определяют **категории поведения** атакующего. Используется таксономия MITRE ATT&CK, включающая 14 тактик, от Initial Access до Impact. Каждая тактика — вершина с атрибутами `tactic_id`, `description`, `phase`.

Методический уровень

На этом уровне описываются **конкретные техники**: - T1566.001 — Spearphishing Attachment; - T1059.001 — PowerShell; - T1071.001 — Web Protocols.

Вершины снабжаются атрибутами `technique_id`, `cve`, `tool`, `detection_rule`.

Межуровневые связи и их семантика

Связи между уровнями не являются произвольными. Они отражают причинно-следственные и логические зависимости: - Дуга `realizes(g, t)` означает, что достижение цели g требует применения тактики t ; - Дуга `implements(t, m)` указывает, что тактика t может быть реализована через метод m ; - Дуга `requires(m1, m2)` фиксирует зависимость: метод $m1$ невозможен без предварительного выполнения $m2$.

Эти связи формируют **иерархический атрибутивный метаграф**, который служит основой для построения эталонных паттернов атак.

Методика выявления атак

Этап 1. Построение эталонного метаграфа угроз

Эталонный метаграф G_{ref} строится на основе:

- официальной базы MITRE ATT&CK;
- реестра уязвимостей CVE/NVD;
- внутренних отчётов ИБ-команды;
- методики определения угроз [2];

- работы Новохрестова и Конева [3].

Каждая известная атака (например, APT28, Lazarus) представляется как подграф $G_{\text{ref}}^{(i)}$, содержащий цепочку: цель $\rightarrow$ тактики $\rightarrow$ методы $\rightarrow$ уязвимости.

Этап 2. Сбор и нормализация событий

События поступают из разнородных источников:

- EDR-агенты (запуск процессов, доступ к файлам);
- Сетевые IDS (аномальные потоки);
- Логи веб-серверов и баз данных.

Все события нормализуются в единый формат CEF или JSON, затем отображаются в метаграф наблюдений G_{obs} .

Этап 3. Алгоритм сопоставления

Задача сводится к поиску **частичного изоморфизма** между $G_{\text{ref}}^{(i)}$ и подграфом G_{obs} . Используется рекурсивный алгоритм с эвристической фильтрацией по атрибутам `technique_id` и `tactic_id`.

Этап 4. Оценка достоверности и реагирование

Для гипотезы атаки рассчитывается вес:

$$W(H_i) = \alpha \cdot S_{\text{struct}} + \beta \cdot S_{\text{attr}} + \gamma \cdot C_{\text{crit}},$$

где S_{struct} — структурное совпадение, S_{attr} — совместимость атрибутов, C_{crit} — критичность цели. При $W(H_i) > 0.85$ генерируется алерт.

Научная новизна

Предложенный подход вносит следующий вклад в область обнаружения кибератак:

1. **Формализация атаки как иерархического атрибутивного метаграфа**, объединяющего стратегические цели, тактики (MITRE ATT&CK) и техники реализации в единую семантическую структуру с гиперсвязями. Это принципиально отличает модель от деревьев атак и классических графов.
2. **Алгоритм частичного изоморфизма с онтологически обоснованной совместимостью атрибутов**, устойчивый к обфускации и LotL-техникам.
3. **Интеграция регуляторных требований (ФСТЭК, ГОСТ Р 56939–2024)** непосредственно в модель через атрибуты, что обеспечивает соответствие отечественным стандартам защиты информации.

В работе впервые предложена **онтологически насыщенная, регуляторно-ориентированная модель выявления атак**, основанная на структурно-семантическом анализе атрибутивных метаграфов.

Оценка эффективности

Описание эксперимента

Эксперимент проведён в изолированной среде на базе CALDERA 4.0 и Proxmox VE 8.1, включающей:

- 50 сценариев атак (Log4Shell, phishing, PowerShell lateral movement, DNS tunneling);
- 1000 событий легитимной активности;
- контрольный модуль на основе SIEM-правил (Sigma + Elastic Detection Rules).

Результаты

Метод на основе атрибутивных метаграфов показал:

- Точность — 94,3 %, полнота — 89,7 %, ложные срабатывания — 3,1 %;
- Среднее время реакции — 1.8 с (против 5.4 с у SIEM);
- Устойчивость к увеличению фона: снижение F1-меры всего на 1.2 % при 10× шуме.

Сравнение с графами знаний [4] показало преимущество по полноте (+11.5 %) и скорости анализа (на 220 мс быстрее).

Сравнение с альтернативными подходами

Подход	Контекст	Обобщение	Обфускация	Интерпретируемость
Сигнатурный IDS	Нет	Низкое	Низкая	Высокая
ML-аномалии	Частично	Среднее	Средняя	Низкая
Графы знаний	Да	Среднее	Средняя	Средняя
Атрибутивные метаграфы	Полный	Высокое	Высокая	Высокая

Предложенный метод сочетает **интерпретируемость** и **семантическую глубину**, что делает его пригодным для использования в регулируемых секторах (госсектор, финансы, критическая инфраструктура).

Практическая применимость и рекомендации

Методика может быть внедрена в:

- SIEM/SOAR-платформы (IBM QRadar, Splunk, Elastic Security);
- Собственные решения, сертифицируемые ФСТЭК.

Рекомендации:

- Начинать с сегмента DMZ;
- Использовать MITRE ATT&CK Navigator для визуализации покрытия;
- Интегрировать с системами управления уязвимостями (Nessus, OpenVAS).

Ограничения и направления развития

- Требуется начальная разметка эталонных атак (перспектива — полуавтоматизация через LLM);
- Не учитывает временные зависимости (в будущем — гибрид с временными графами);
- Зависит от качества нормализации событий (рекомендуется CEF/Syslog).

Заключение

Предложенная методика выявления компьютерных атак на основе атрибутивных метаграфов обеспечивает высокую эффективность за счёт глубокого семантического моделирования логики атаки. Подход позволяет обнаруживать сложные, малозаметные сценарии, которые остаются незамеченными традиционными средствами. Методика соответствует современным требованиям к системам защиты информации и может быть успешно интегрирована в инфраструктуру безопасности государственных и коммерческих организаций.

Список литературы

1. *Latypov I. T., Ereemeev M. A.* Multilevel Model of Computer Attack Based on Attributive Metagraphs // Automatic Control and Computer Sciences. — 2020. — Т. 54, № 8. — С. 944—948. — DOI: 10.3103/S0146411620080192.
2. *ФСТЭК России.* Методика определения угроз безопасности в информационных системах : тех. отч. — Москва, 2015.
3. *Новохрестов А. К., Конев А. А.* Оценка качества защиты компьютерных сетей // Динамические системы: Механика и машиностроение. — 2014. — С. 85—87.
4. Cyber Threat Intelligence Modeling Based on Heterogeneous Graph Neural Network / Y. Li [и др.] // USENIX Security Symposium. — 2022.

УДК: 004.738.7

ББК: 32.973.26-018.2